

CYBEROPS

Progetto : CyberOps 5(U3S11L5)

Di : Nicola Cuocci

ESERCIZIO 1: Gestione del sistema tramite Windows PowerShell

- **Inizializzazione degli ambienti:** Avvia in parallelo due terminali distinti: una sessione di PowerShell e una del Prompt dei Comandi tradizionale (CMD). Questo approccio ti permetterà di mettere a confronto il comportamento dei due software.
- **Analisi comparativa:** Digita il comando `dir` in entrambe le interfacce. Sebbene i risultati visivi si somiglino, all'interno dell'ambiente PowerShell `dir` non è un comando autonomo, ma funge da alias per il cmdlet nativo `Get-ChildItem`.
- **Studio dei cmdlet:** I comandi strutturati di PowerShell seguono la convenzione sintattica Verbo-Nome. Per tracciare l'effettivo cmdlet nascosto dietro un'abbreviazione, esegui `Get-Alias dir`, il quale mostrerà il collegamento: `dir -> Get-ChildItem`.
- **Monitoraggio di rete avanzato:** Elevando PowerShell con i permessi di amministratore, è possibile esaminare lo stato delle connessioni di rete:
 - `netstat -h`: Visualizza la guida in linea con l'elenco completo dei parametri utilizzabili.
 - `netstat -r`: Mostra lo stato corrente della tabella di routing per i protocolli IPv4 e IPv6. Nei dati presi ad esempio, il gateway predefinito IPv4 corrisponde a `192.168.1.1`.
 - `netstat -abno`: Ispeziona i collegamenti TCP attivi, evidenziando il nome dell'eseguibile e il relativo identificativo di processo (PID). Ad esempio, il PID 756 è associato a `svchost.exe` per la gestione del servizio `RpcSs`.
 - Incrociando tali record con i dettagli del Task Manager, si può risalire alla paternità di ogni sessione di rete, isolando dati quali: nome dell'applicazione, account utente, stato operativo, risorse hardware allocate (CPU/RAM) e nota informativa.
- **Manutenzione dello storage:** Per ripulire lo spazio residuo direttamente dal terminale, si utilizza il cmdlet `Clear-RecycleBin`. Il sistema richiederà una convalida esplicita (`[Y]` Yes) prima di procedere alla rimozione definitiva degli elementi.

ESERCIZIO 2: Analisi degli Indicatori di Compromissione (IoC)

URL analizzato: <https://app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281/>

Panoramica dell'analisi

ANY.RUN è una sandbox interattiva di analisi malware che esegue campioni in un ambiente Windows isolato e ne registra ogni comportamento. Il task analizzato mostra l'esecuzione di un campione classificato come **AgentTesla**, un **infostealer/RAT** (Remote Access Trojan) ampiamente diffuso.

Classificazione della minaccia

Campo	Valore
Famiglia malware	AgentTesla (Infostealer / RAT)
Livello di rischio	ALTO — Malicious
Vettore iniziale	File eseguibile (.exe) consegnato tramite phishing
Tecnica principale	Process Injection + Persistence via registro di Windows
Obiettivo	Esfiltrazione credenziali, keylogging, screenshot

Comportamento osservato (TTP — MITRE ATT&CK)

T1059 — Command & Scripting Interpreter

Il campione lancia processi cmd.exe e PowerShell per eseguire comandi di sistema, raccogliere informazioni sull'host e scaricare componenti aggiuntivi.

T1547 — Boot/Logon Autostart Execution

Crea chiavi nel registro (HKCU\Software\Microsoft\Windows\CurrentVersion\Run) per garantire la persistenza al riavvio del sistema.

T1055 — Process Injection

Inietta codice malevolo in processi legittimi (es. RegAsm.exe) per eludere l'antivirus e operare con i privilegi del processo ospite.

T1056 — Input Capture (Keylogging) Registra i tasti premuti dall'utente per catturare credenziali e dati sensibili.

T1113 — Screen Capture

Cattura screenshot periodici del desktop della vittima.

T1041 — Exfiltration Over C2 Channel

Esfiltrazione dei dati raccolti verso un server C2 tramite protocollo SMTP o HTTP/S su indirizzi IP classificati come malevoli

Indicatori di Compromissione (IoC)

Tipo IoC	Valore / Descrizione
Hash SHA256	Identificativo univoco del campione eseguibile analizzato
Processo sospetto	RegAsm.exe avviato da processo non nativo (.NET abuse)
Chiave registro	HKCU\Software\Microsoft\Windows\CurrentVersion\Run
Connessione C2	Traffico verso IP esterni su porte SMTP (587) e HTTP (80/443)
Mutex	Creazione mutex unico per evitare doppia esecuzione
File drops	File .tmp e .dat nella cartella %APPDATA% o %TEMP%

BONUS 1: Tecniche di Scansione con Nmap

Obiettivo: Acquisire familiarità con Nmap, strumento essenziale per la mappatura dei perimetri di rete nelle attività di sicurezza informatica.

Fase 1 - Consultazione della Documentazione

Sui sistemi Linux (come la CyberOps Workstation utilizzata in questo scenario) è possibile studiare il manuale applicativo tramite il comando `man nmap`. Questa utility open source permette di individuare host attivi, mappare porte aperte, identificare servizi remoti e rilevare i sistemi operativi in uso.

Il comando preso come riferimento iniziale è: `nmap -A -T4 scanme.nmap.org`

- **-A:** Attiva in un'unica soluzione il fingerprinting del sistema operativo, l'identificazione delle versioni dei servizi software, l'esecuzione di script di diagnostica e il tracciamento del percorso di rete (traceroute).
- **-T4:** Accelera i tempi di esecuzione della scansione impostando un profilo temporale aggressivo.

Fase 2 - Test sul Campo

- **Ispezione della subnet locale:** Identificato preliminarmente l'indirizzo della propria interfaccia virtuale tramite il comando `ip address` (es. `10.0.2.15/24`), si procede alla scansione dell'intero segmento di rete: `nmap -A -T4 10.0.2.0/24`
 - **Esito su singolo target (10.0.2.15/24):** Rilevata la porta 21/tcp aperta associata al servizio FTP (vsftpd 2.0.8), con autenticazione anonima abilitata e una falla di sicurezza evidente.
 - **Esito sull'intera rete:** Individuati 4 nodi attivi sul segmento, con l'esposizione dei servizi sulle porte 21 (FTP), 22 (SSH) e 23 (Telnet).
- **Verifica su un obiettivo remoto:** Sfruttando la piattaforma didattica ufficiale: `nmap -A -T4 scanme.nmap.org`
 - **IP rilevato:** 45.33.32.156
 - **Piattaforma:** CyberOps Workstation
 - **Porte Accessibili:** 22 (SSH - OpenSSH 6.6.1), 80 (HTTP - Apache 2.4.7), 9929 (nping-echo), 31337 (tcpwrapped).
 - **Porte Schermate (Firewall):** 25 (SMTP), 135 (MSRPC), 139 (NetBIOS), 445 (SMB), 593, 4444.

BONUS 2: Analisi di un Attacco SQL Injection a un Database MySQL

Inquadramento teorico: Le vulnerabilità di tipo SQL Injection si verificano quando un'applicazione non valida adeguatamente i dati inseriti dall'utente, permettendo

l'iniezione di frammenti di codice SQL nei moduli web. Ciò inganna il database costringendolo a elaborare istruzioni impreviste e a mostrare informazioni riservate.

Il tracciamento mostra l'interazione tra due nodi principali: l'indirizzo IP **10.0.2.4** (postazione dell'attaccante) e l'IP **10.0.2.15** (server web vittima configurato con Apache e MySQL).

- **Fase 1 - Ispezione del traffico:** Il file `SQL_Lab.pcap` viene aperto in Wireshark per isolare i flussi informativi tra le due macchine (**10.0.2.4** e **10.0.2.15**).
- **Fase 2 - Test di vulnerabilità:** L'attaccante immette la stringa `1=1` all'interno del campo UserID. Trattandosi di una condizione logica universale e sempre vera, un'applicazione non protetta bypassa i filtri ordinari. Il server risponde infatti mostrando i dati dell'account amministrativo, confermando la presenza del difetto logico.
- **Fase 3 - Esplorazione del database e dell'identità utente:** Viene sferrata la richiesta: `1 or 1=1 union select database(), user()` Il sistema risponde esponendo:
 - Nome dello schema logico: `dvwa`
 - Account di esecuzione: `root@localhost` (profilo con massimi privilegi amministrativi)
 - Elenco di credenziali aggiuntive presenti nel sistema.
- **Fase 4 - Identificazione della release software:** Viene iniettata la sintassi: `1' or 1=1 union select null, version()#` La risposta restituisce la versione esatta: `MySQL 5.7.12-0ubuntu1.1`. Questo dato permette all'attaccante di cercare exploit specifici per quella build.
- **Fase 5 - Mappatura del dizionario dati:** L'attaccante interroga il dizionario interno tramite il comando: `1' or 1=1 union select null, table_name from information_schema.tables#` Il database restituisce l'elenco delle tabelle archiviate (tra cui `INNODB_SYS_COLUMNS`, `guestbook`, `users`, `columns_priv`). L'attenzione dell'attaccante si focalizza sulla tabella `users`. Una restrizione mirata con la clausola `WHERE table_name='users'` avrebbe permesso di estrarre in modo diretto la struttura delle colonne (campi utente, password, ecc.).
- **Fase 6 - Esfiltrazione finale delle credenziali:** Viene eseguito il comando per l'estrazione dei record sensibili: `1' or 1=1 union select user, password from users#` L'output mostra gli account utente abbinati ai rispettivi hash crittografici MD5 delle password:

UTENTI	HASH
admin	5f4dcc3b5aa765d61d8327deb882cf99
gordonb	e99a18c428cb38d5f260853678922e03
1337	8d3533d75ae2c3966d7e0d4fcc69216b
pablo	0d107d09f5bbe40cade3de5c71e9e9b7
smithy	5f4dcc3b5aa765d61d8327deb882cf99